

From a Production OTP Flood to a Layered Defence: Measured Limits of Risk-Scored SMS Verification Against Residential Flooders and Colluding Carriers

Naveed Ahmed^{a,*}

^a*Affiliation to be completed before submission, Saudi Arabia*

Abstract

An endpoint that sends a one-time password by SMS to any number it is given will be abused, to waste money (flooding) or to earn part of the termination fee (SMS pumping). Starting from such an incident, as its operator recalls it, we present a twelve-step pipeline that derives trust from app attestation, signed sessions and verification outcomes, and evaluate it in simulation, with paired legitimate traffic, against six simpler designs and 25 attacker profiles. A protocol committed before the main runs fixed comparator selection and five robustness claims; all hold, after a pairing defect that failed one claim in the first run was repaired. Attacks with a signature in the request are contained with completion within two points of the no-attack run. A residential attacker with farmed CAPTCHA scores was not separated by any tested signal without challenging nearly half of legitimate users; an adaptive cap held it to 46% of its requests by refusing 54% of first-time users. Sequential tests of verification outcomes on three pumped destination blocks leaked 89 of about 560 messages, but 405 when the carrier verified 60% of its codes. At a matched service target, a short-window counter of SMS sends per block leaked 6 to 48 messages against every pumper tested, at an attributable completion loss of 0.06 to 0.43% of users.

Keywords: SMS pumping, artificially inflated traffic, one-time password, rate limiting, risk scoring, residential proxies, sequential tests, fraud prevention

*Corresponding author.

Email address: optimistbs@gmail.com (Naveed Ahmed)

1. Introduction

Most online services verify a phone number by sending it a code by SMS, from an endpoint reachable before any account exists, at a tenth of a cent to twenty cents a message. A flooder makes the service send to numbers it does not own; a pumper sends to a range whose operator shares the termination fee, turning the service’s SMS budget into its income [1]. Twitter’s owner said in 2023 that pumping had cost the company about 60 million dollars a year [2], and Huh et al. found as many attack requests as genuine ones in three months of one large service’s logs [3].

This paper starts from such an incident on a registration flow the author operated. A hidden CAPTCHA, per-number and per-address limits, a country allow-list and a proxy block stopped the first attack. The one that came back rotated residential addresses, sent the header that marked a request as coming from the iOS app, and stayed under every threshold. The redesign is a twelve-step pipeline: attestation-backed platform exemptions, signed sessions, number checks before a message is paid for, key reputation built from whether codes were entered, a risk score choosing among five responses, and a hard budget.

We evaluate it in simulation under a protocol committed before the main runs, asking which attacks it contains against simpler designs, and at what cost in completed registrations (RQ1); which layer is responsible (RQ2); when outcome-based reputation separates an attacker from simulated users (RQ3); what rationing costs when it does not (RQ4); and what destination policies cost legitimate users (RQ5). We contribute the incident as eight named gaps, the design and an open implementation, measurements of where reputation stops separating and what rationing depends on, a closed-form leakage estimate, a matched comparison of destination policies, and a collateral-damage study. The most useful finding is negative for our own detector: on the one key a pumper cannot rotate, counting SMS sends did better overall than testing what happened to them.

2. Background and related work

Revenue-share fraud. In international revenue share fraud, traffic is generated to an advertised number range and the termination fee is split along the route [4]. Sahin and Francillon collected 3.14 million test numbers from twelve providers over four years; the range is the fraudster’s managed asset,

36 about 80% of ranges being shared across providers [5]. Acting on ranges is
37 risky: their range-based detector had 5.8% false positives against 0.26% for
38 a classifier on call features.

39 *Detecting artificially inflated SMS.* Huh et al. trained gradient-boosted trees
40 on 9.4 million SMS authentication logs from nineteen countries, reaching
41 89.6% recall at 0.19% false positives on web traffic and 91.1% at 0.11% on
42 native traffic [3]. About 73% of web attacks sent four or fewer requests
43 per identity a day, defeating per-entity limits; destination signals were the
44 strongest, with about 92% zero conversion for attacks against 21% for gen-
45 uine traffic. Their detector learns request, entity and country features from
46 labelled traffic and acts per request; ours hand-specifies one feature family,
47 outcomes and volume per destination block, and acts per block. We did
48 not reproduce theirs, and ours is one transparent, evaluated instance, not a
49 representative of the family.

50 *Defences in practice.* Twilio’s Fraud Guard blocks regions known for pump-
51 ing [6]; its SMS Pumping Risk Score rates numbers from carrier, traffic
52 and conversion signals and advises friction from 60 and refusal above 90 [7].
53 Graded destination action is thus established practice, with an unpublished
54 model; no product was benchmarked. CAPTCHA solving is a labour market
55 at about a dollar per thousand [8], open where machine solvers fail [9]; client
56 puzzles [10] were not evaluated. Residential proxy addresses rotate within
57 minutes and are rarely blacklisted [11], and carrier-grade NAT makes address
58 reputation on cellular networks “all but infeasible” [12].

59 *Identity and change detection.* One entity can present many identities [13];
60 a signed session gives continuity, not scarcity. Our block tests are Wald’s se-
61 quential tests [14] run as Page’s cumulative sums [15]. Quickest change detec-
62 tion minimises delay subject to false-alarm constraints [16], and a CUSUM’s
63 parameters are set from the error rates it must meet [17]; an unconstrained
64 grid is a set of sampled operating points, which is how we report ours. Con-
65 fidence sequences [18] and windowed statistics were not evaluated. Step 7
66 resembles risk-based authentication [19]; attacks on the code once sent are a
67 separate problem [20, 21].

68 3. The incident and the adapted attacker

69 This section is motivation, not evidence: no logs from the period are
70 in our hands, and permission to describe the incident is being sought. The

71 registration flow sent an SMS to any unregistered number. The first controls,
 72 v1, were reCAPTCHA v3 on web requests, one message per number per
 73 minute, five requests per address per minute, a country allow-list, a body-
 74 length limit, a proxy block and per-platform caps. The returning abuse
 75 used thousands of residential addresses, carried the iOS header to skip the
 76 CAPTCHA, and stayed under every limit. Table 1 separates the gaps the
 77 operator recalls from those the later design review found.

Table 1: The v1 controls and their gaps. Source: R, recalled from the incident; D, found in the design review that followed.

Gap	Src.	v1 assumed	How it fails
A	R	A platform header says which app sent the request	Sending the header reached every exemption
B	R	Five requests per address per minute bound an attacker	A fresh residential address per request
C	R	A number given is worth sending to	Generated numbers cost as much as real ones
D	D	An allowed country is a safe destination	Premium ranges inside it cost far more
E	R	Per-key caps bound total spend	A wide attack under every cap
F	D	Check-then-increment is a rate limit	Two racing instances both pass
G	D	Bulk and test flags are internal	Neither needs stronger authentication
H	D	Each check says which check failed	Thresholds can be probed one at a time

78 *Threat model.* The attacker wants as many messages sent as possible, or
 79 sent to numbers that pay it. It buys residential proxies (about 3 USD per
 80 gigabyte) and human-like reCAPTCHA tokens (about 0.3 cents), mints fin-
 81 gerprints, generates numbers and knows the thresholds. A pumper also has
 82 a colluding operator’s ranges; it may enter the codes delivered there, report
 83 deliveries as failed, build verified history and buy challenge solutions. It can-
 84 not forge an attestation, change which ranges its partner terminates or make
 85 a stranger enter a code. Undelivered messages are assumed billed, which
 86 favours the attacker.

87 4. Design

88 No message is paid for before every check passes, and cheap checks run
 89 first. Trust comes from evidence the client cannot forge, an attestation, a
 90 server-signed session and the fate of earlier codes, though such evidence can
 91 be manufactured (Section 7.8).

92 4.1. The pipeline and the risk score

93 A request passes the steps of Table 2 until one refuses it. Step 0 takes
 94 the platform only from a valid App Attest or Play Integrity result, ignor-
 95 ing the header. Each address limit, per-number slot, budget reservation and
 96 per-block counter slot is one atomic Redis operation, released if a later step
 97 refuses; the enclosing steps also make separate writes (Section 6). Every out-
 98 come after Step 0 except the challenge returns one HTTP 200 body padded
 99 to 400 ms.

Table 2: The twelve steps and the v1 gap each targets. FB is the feedback loop.

Step	Check	Gap
0	Proxy block; platform from attestation, never from the header	A
1	Signed session bound to a fingerprint; 3 requests per session per 10 min	B
2	Limits per address, /24 and ASN, lower for hosting ASNs	B, F
3-4	reCAPTCHA v3 threshold and origin check, web only	—
5	Number intelligence: cost class, sequential numbers, liveness; reads the block’s verdict stage	C, D, G
6	Body length, excluded numbers; test bypass needs a credential	G
7	Risk score and tier: allow, delay, challenge, downgrade, block	H
8	Per-number backoff, 60s doubling to 1 h, five a day	—
9	Per-source, platform and country caps with an adaptive multiplier	—
10	Operating mode: elevated above 80% of the hourly budget, emergency at 100%	E
11	Reserve hourly count and spend (no send over either); write state; enqueue; uniform response	E, H
FB	Verified, failed, undelivered per key; destination-block tests; denylist of fine keys	—

100 Step 7 computes

$$s = \sum_i w_i x_i + w_c \frac{\max(0, \theta - r_{\min})}{\theta} + w_s f + w_m i - w_v v_n - w_f v_f, \quad (1)$$

101 where the x_i are request signals (CAPTCHA score, hosting ASN, finger-
 102 print age, session requests, country mismatch, number class), $r_{\min}$ is the
 103 lowest conversion ratio over the request's keys (address, subnet, ASN, fin-
 104 gerprint, country, prefix, destination block), $\theta = 0.3$, $w_c = 25$, f and i flag
 105 a flooded key and one whose codes are entered within seconds, and v_n , v_f
 106 mark a number and fingerprint with verified history; other weights are 5 to 25
 107 points [22]. Tiers start at 20, 40, 60 and 80: *allow*; *delay* (a doubling wait);
 108 *challenge* (credits -20 when solved); *downgrade* (push or WhatsApp, never
 109 SMS); *block*. The conversion penalty lands on keys legitimate users share,
 110 so alone it reaches only *delay*; a datacenter address with a fresh fingerprint
 111 scores about 47, *challenge*, so datacenter rotation is stopped only while the
 112 attacker declines challenges.

113 4.2. The feedback loop

114 A send resolves as *verified* when its code is entered, *failed* after five wrong
 115 attempts or two minutes past the delivery receipt, and *undelivered* without
 116 a receipt in sixty seconds or with a failure receipt; only the first two feed
 117 reputation. A negative receipt marks the send failed and undelivered in
 118 one compare-and-set; a later positive receipt reopens it while the code is
 119 valid; a late verification reclassifies it, but an issued verdict stands until it
 120 expires. Each transition records its effects in the same write and applies them
 121 idempotently; a recovery sweep finishes a dead process's work.

122 4.3. Destination-block tests

123 Every key above can be rotated except the destination: a pumper is paid
 124 only on its partner's numbers. We key reputation on the 8-digit block (10 000
 125 numbers) with two log-likelihood-ratio statistics. The conversion statistic
 126 assumes users verify with $p_\ell = 0.8$ and a flooder with $p_a = 0.1$: a failure adds
 127 $\ln \frac{1-p_a}{1-p_\ell} = 1.50$, a verification $\ln \frac{p_a}{p_\ell} = -2.08$. The speed statistic assumes
 128 a machine enters a verified code within five seconds with $q_a = 0.9$ and a
 129 person with $q_\ell = 0.2$, since autofill removes the keystroke [23, 24]; it adds
 130 1.50 or -2.08 . A verdict is issued, and the statistic reset, when either exceeds
 131 $h = \ln 1000 = 6.91$.

132 The floor sets the detector's memory: $S_t = \max(-ch, S_{t-1} + \text{increment})$.
 133 Unbounded c is Wald's test and $c = 0$ Page's cumulative sum; with $Y_t =$
 134 $S_t + ch$, any finite c is a zero-floor CUSUM with threshold $(1+c)h$ and head
 135 start ch , so thresholds and credits form one grid. The default is $c = 1$.

136 A first verdict makes the block’s first-time clients pass a challenge for an
 137 hour; a second within the hour moves them off SMS, refusing those without
 138 another channel. The stage is decided in the crossing’s atomic write. Clients
 139 with verified history are exempt; a 24-hour denylist is a comparator. Tests
 140 pause on a prefix during a detected carrier outage.

141 *The counter comparator.* The simplest destination policy counts SMS sends
 142 per block. Step 5 reads the count and Step 11 reserves a slot atomically only
 143 when an SMS is about to go out, so a refused or challenged request and its
 144 retry cost nothing. Windows are daily or short and refilling; past the limit
 145 the counter refuses, or acts like a verdict (challenge past the limit, non-SMS
 146 past twice the limit).

147 4.4. Capacity controls

148 Step 9 multiplies its caps by 0.25 to 1.5 according to a baseline job com-
 149 paring each key with its expected rate, learned from the pipeline’s hourly
 150 counters as a weekly profile or from the closed hours available; with none,
 151 the static cap stands. The default job runs every minute. Verified history
 152 avoids the adaptive reduction, not the static caps or budget, and the budget
 153 bounds SMS count and spend units, not vendor or fallback costs.

154 5. An estimate of pumping leakage

155 Against the block tests, leakage depends on the blocks a pumper touches.
 156 With B blocks reached, rate λ , N requests and $k = \lceil h/1.50 \rceil = 5$ sends per
 157 block before a verdict,

$$L \approx \min(N, kB + \lambda \tau), \quad (2)$$

158 where τ , the time a send stays unresolved, is about 2.5 minutes if the carrier
 159 never verifies and seconds if it verifies at once. It assumes no pre-existing
 160 credit on the blocks, no successfully solved challenges, no verified-history
 161 exemptions and no outage suspension, and predicts the first verdict, not
 162 containment under graded action. Evaluated on each run’s observed blocks
 163 it checks the per-block mechanism; it is not a forecast, and once $kB > N$ it
 164 only says everything leaks.

165 A carrier verifying a share σ of codes with human-like delay gives the
 166 conversion statistic an expected increment of $\sigma(-2.08) + (1 - \sigma)(1.50)$, zero
 167 at $\sigma^* = 0.42$. Below it detection is expected, later as σ nears σ^* ; above it the

168 drift is away from the threshold, and a verdict in a finite window depends on
169 the floor and on runs of failures.

170 6. Implementation and evaluation method

171 *Implementation.* About 3 700 lines of Python implement the pipeline, feed-
172 back loop and adapters (reCAPTCHA, Play Integrity, App Attest with en-
173 rolment tested only on synthetic certificate chains, IP intelligence, number
174 lookup, SMS, WhatsApp) on in-memory and Redis backends. Step 11 writes
175 the audit record, counters and OTP entry before calling the sender, so a
176 synchronous callback finds registered state; these are separate writes, and
177 a crash between them leaks reserved slots or resolves the send as undeliv-
178 ered. Of 353 tests, eight run two instances on a real `redis-server` and
179 check, on that backend only, the hourly ceiling, single claims of a number,
180 callback counting, block-event counting with graded escalation, recovery of
181 a dead process’s transition, mixed receipts and compare-and-set. Two in-
182 terleavings remain open: a correcting receipt landing between the timeout
183 worker’s decision and its removal of the timeout leaves the send unresolved,
184 and a late reversal racing a failure can inflate a block’s failure count. The
185 single-threaded simulator exercises neither. No live vendor was called.

186 *Simulation.* The pipeline runs against scripted vendor fakes on a simulated
187 clock. After a ten-minute warm-up (130 for pumping), each run has twenty
188 minutes of attack over legitimate traffic at 20 requests per minute. Simulated
189 users verify 80% of codes after a lognormal delay (median 22s; 2s for the 20%
190 using autofill); 70% have a WhatsApp-reachable number, registered with the
191 channel selector; 90% complete a challenge; 20% come from a population
192 of 5 000 account holders with a stable fingerprint and a trusted number.
193 Legitimate and attacker requests use separate random streams, so at a seed
194 every scenario, no attack included, offers the same users; tests assert identical
195 trace hashes, immutable cohorts and a full drain. The baseline job is told
196 the legitimate rate except in Section 7.4.

197 Behavioural parameters are assumptions, annotated with any published
198 figure behind them (one provider reports 68% conversion [25]). The main
199 study uses thirty seeds per attacker and draws pool size, rate and CAPTCHA
200 class per seed; fixing them narrows the farm’s interval from [215, 244] to
201 [223, 232] messages, so most spread is attacker variation. Other studies use
202 ten seeds (five for dilution and the 24-hour fallback and design-alternative

203 cells; eight for the outage). Brackets are 95% percentile-bootstrap intervals,
 204 paired per seed for differences. Source caps are lifted or set at three times
 205 the legitimate rate.

206 *Predeclared protocol.* A protocol committed before the runs that use it fixes
 207 two studies. The *matched comparison* changes only the destination policy
 208 on the full pipeline (block conversion still feeds the risk score in every row);
 209 within each family and density it selects, on three tuning seeds, the lowest-
 210 leakage setting whose completion is within 0.5 points of the default’s, and re-
 211 ports it on ten other seeds. The *robustness study* fixes twelve Latin-hypercube
 212 points over conversion (0.6–0.9), autofill, human CAPTCHA scores, What-
 213 sApp reachability (0.3–1.0), returning share and legitimate rate; a held-
 214 out family of attack rates (60 to 120 per minute), pools (50 000 to 500 000
 215 addresses) and heterogeneous legitimate traffic (per-block conversion, poor
 216 routes, resends, a burst); and five claims that hold if true in 90% of cells,
 217 three seeds per point. The first run failed claim C1 in 32 of 108 cells, all on
 218 its service clause: attack and no-attack runs shared one random stream, so
 219 the clause compared different users. We fixed the pairing, left the protocol
 220 unchanged and reran every study; the first run is in the artifact. The fix
 221 followed a result, and readers should weigh it so.

222 *Designs and metrics.* Feature flags give seven designs: **v1** (header-trusted
 223 platform, static caps), **v1-corrected** (platform from attestation), **budget-**
 224 **only** (sessions, static caps, budget), **block-limit** (sessions, a refusing counter
 225 of five sends per block per day), **conversion-only** and **speed-only** (v2
 226 minus one block test), and **v2**. We report leakage; seeds *contained* (leakage
 227 at most 5% of the attack rate from some minute to the window’s end, for
 228 at least five minutes), a finite-window property; time to containment over
 229 contained seeds; completion, challenge and refusal per offered legitimate user;
 230 and verdict events inside the window. Requests that met a verdict and
 231 never completed are a *descriptive* count; *attributable* loss compares the same
 232 requests with the policy enforced and absent, net of the reverse. Table 3 lists
 233 the attackers.

Table 3: The 25 attacker profiles by artifact name; the spread study adds 18 generated pumpers. Residential profiles use in-country ranges; farmed CAPTCHA scores follow the human distribution. Parameters: `results/attacker_profiles.md`.

Profile	Description
<code>naive_single_client</code>	One address and session, bot scores
<code>datacenter_rotation</code>	Hosting ASN abroad, fresh fingerprint per request
<code>residential_bot, _captcha_farm, _aged_fps</code>	Fresh fingerprints; bot, farmed, or farmed with aged fingerprints
<code>residential_reused_profile</code>	One 48-hour-old browser profile
<code>sequential_numbers, premium_pumping</code>	Numbers walked upward; a premium-rate prefix
<code>spoofed_platform</code>	The farm sending the iOS header without attestation
<code>pumper_verifies_{instantly,humanlike}</code>	Elevated-cost range; verifies all within 1 s, or 60% after 30 s
<code>pumper_standard_range_humanlike</code>	All standard prefixes, 60% verified after 30 s
<code>challenge_solver</code>	Datacenter rotation buying every challenge solution
<code>low_and_slow_{20_asns,below_dilution}</code>	2 or 10 requests/min over 20 residential ASNs
<code>trust_building_{pumper,concentrated, long}</code>	500 identity/number pairs verify for 10 (or 30) min, then flood
<code>threshold_aware_carrier</code>	Knows the deployed parameters; enters a code only when its block nears a verdict
<code>receipt_faking_carrier</code>	Reports every delivery failed
<code>block_poisoner</code>	Floods the 20 blocks simulated users concentrate on
<code>concentrated_pumper_*</code>	Three blocks; carrier never verifies, verifies within 1 s or 60% after 30 s, or buys challenges

234 7. Results

235 7.1. RQ1: what is contained, and at what cost

Table 4: Leaked share of about 600 attack requests in twenty minutes, thirty seeds: caps lifted (v1, block-limit BL, v2) and on (v1, v2, with first-time users refused and all users completing). Aged fingerprints behave as the farm. v1-corrected equals v1 except on the forged header (99.5; 96.0, 4.5, 76.4); budget-only equals v1-corrected except on the single client (0.3) and premium pumping (94.9; 94.5, 6.0, 75.3); conversion-only equals v2; speed-only equals v2 except on the walk (13.3; 12.3, 3.8, 77.3).

Attacker	lifted: leaked %			caps on, v1 (%)			caps on, v2 (%)		
	v1	BL	v2	leaked	refused	compl.	leaked	refused	compl.
Single client	5.6	0.3	0.3	5.6	0.9	79.3	0.3	1.1	79.1
Datacenter rotation	69.0	69.0	0.0	66.9	3.2	77.5	0.0	1.1	79.1
Premium pumping	99.4	1.0	0.0	95.7	4.9	76.2	0.0	1.1	79.1
Sequential numbers	99.4	1.0	11.5	95.7	4.9	76.2	10.7	3.5	77.5
Reused profile	99.5	99.5	22.5	96.0	4.5	76.4	17.4	8.6	74.2
Residential bot	37.2	37.2	37.2	37.2	0.9	79.2	29.9	16.2	69.6
Farmed CAPTCHA	99.5	99.5	99.5	96.0	4.5	76.4	45.6	54.0	45.5
Forged header	100.0	99.5	99.5	21.1	0.9	79.3	45.6	54.0	45.5

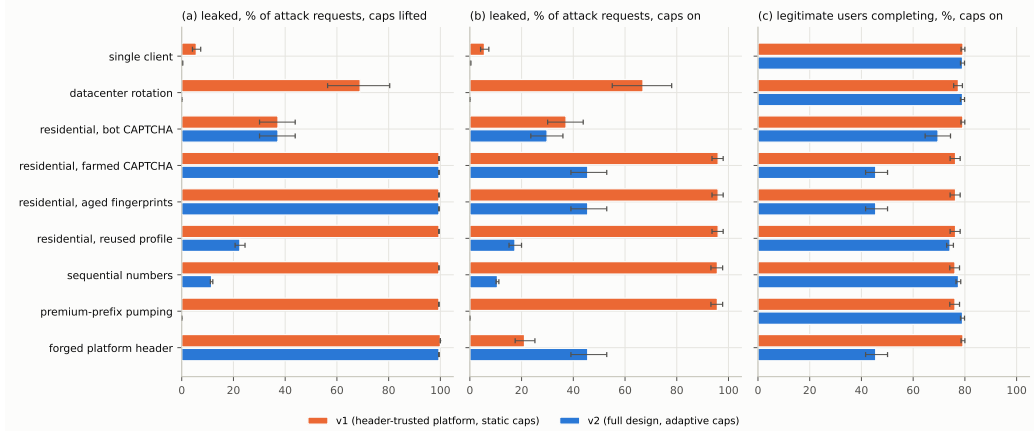


Figure 1: Leaked share of attack requests under v1 (header-trusted platform, static caps) and v2 (full design, adaptive caps), caps lifted (a) and on (b), and legitimate completion with caps on (c); thirty seeds, 95% bootstrap intervals.

236 Datacenter rotation leaks nothing under v2 because every request lands
237 in the challenge tier and this attacker declines challenges; Step 5 refuses
238 the premium range; the session cap holds the single client to two messages
239 (Table 4, Figure 1). Under these attacks 79.1% of users complete with caps
240 on, and in all 108 robustness cells, at held-out attack rates and pools, leakage
241 stayed under 5% with completion within two points of the paired no-attack
242 run (claim C1). The walk leaks 61 [53, 70] messages before its block’s verdict
243 at minute 3.0, costing 1.6 points of completion; the reused profile leaks 88
244 [83, 95], costing 4.9 points as it tightens the adaptive cap.

245 Budget-only contains only the single client. Block-limit stops the walk at
246 five messages, better than v2’s 61, at no measured cost here, and premium
247 pumping at five, where v2 lets none through; Section 7.6 tests destination
248 policies on dense legitimate traffic. The forged header buys nothing under
249 v2, which ignores it; v1 believes it and puts the attacker in the app bucket,
250 whose static cap holds it to 100 messages. Attestation removes the choice of
251 bucket; it does not by itself reduce leakage.

252 The farmed-CAPTCHA attacker leaks 99.5% with caps lifted under every
253 design. With caps on, v1 lets 96% through while refusing 4.5% of first-time
254 users; v2’s adaptive cap holds it to 229 [215, 244] messages, 46%, by refusing
255 54% [47, 60] of first-time users, so 45.5% complete instead of 76.4%. That
256 gain is rationing; claim C5 (v2 leaks at most 0.7 times v1 and refuses ten
257 points more first-time users) held in 36 of 36 cells.

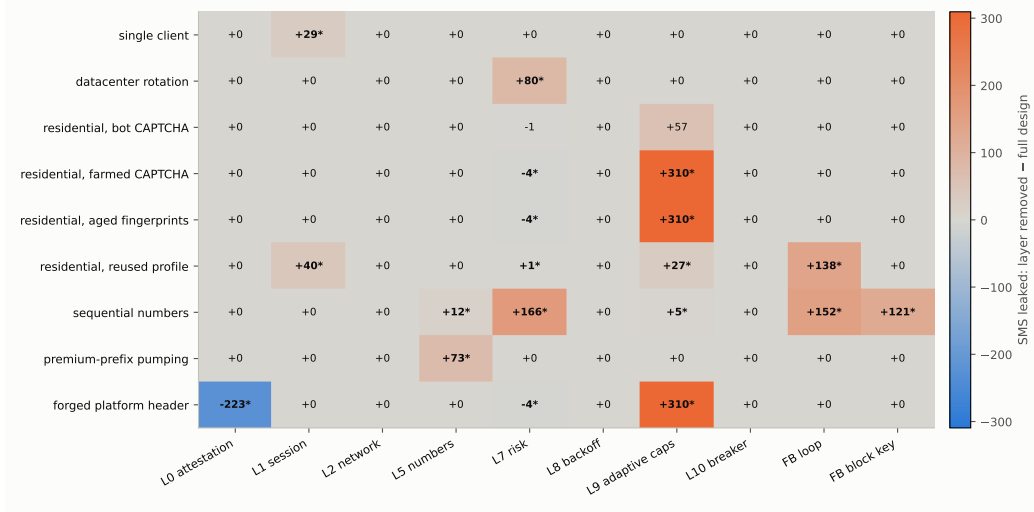


Figure 2: Ablation, caps on: leaked messages with one layer removed minus the full design, paired on ten seeds and one offered trace; * marks a bootstrap interval excluding zero (19 of 90 cells, so an isolated * is weak evidence). L0–L10 are steps; FB is the feedback loop and block key. The matrix with intervals is in the artifact.

258 7.2. RQ2: which layer does what

259 Each signature attack depends on one or two layers (Figure 2): the session
 260 cap for the single client (+29 [+17, +41] messages without it), the risk engine
 261 for datacenter rotation (+80 [+69, +91]), number intelligence for premium
 262 pumping (+73 [+56, +90]). Without the feedback loop the reused profile
 263 leaks 138 [122, 154] more and completion falls 27 points as the adaptive cap
 264 tightens on everyone; the loop, the block key and the risk engine each stop
 265 the walk (+152, +121, +166 without them). Only the adaptive cap matters
 266 materially against the farm: without it 310 [194, 421] more messages leak and
 267 completion rises 29 points. The circuit breaker changes nothing in twenty
 268 minutes; removing attestation under the forged header lowers leakage by 223,
 269 the bucket effect above. Interactions were not estimated.

270 7.3. RQ3: where reputation stops separating

271 A farmed-CAPTCHA attacker uses an address and a fingerprint once and
 272 shares its country, prefix and residential ASN with every legitimate user, so
 273 the penalty its failures earn lands on everyone. The experiments below cover
 274 the settings run, not every setting.

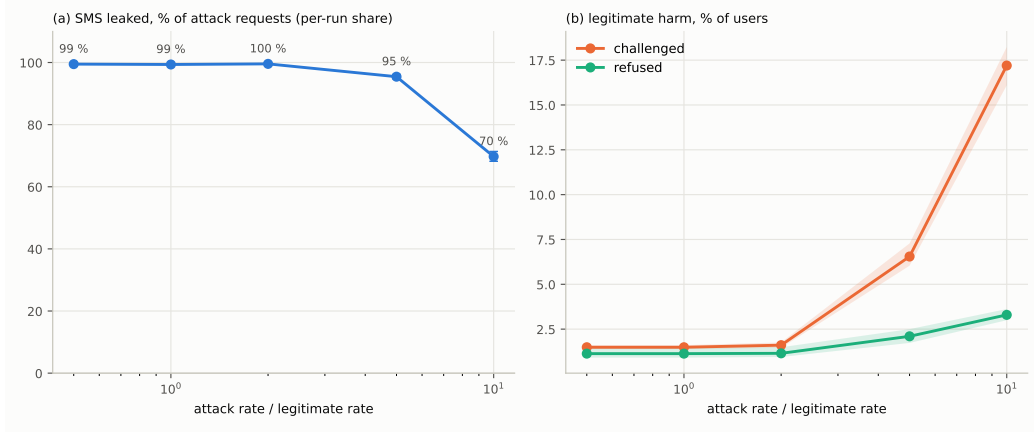


Figure 3: The farm at multiples of the legitimate rate for an hour, caps lifted, five seeds: (a) leaked share per run, with bootstrap intervals narrower than the markers except at $10\times$; (b) legitimate users challenged and refused, with intervals.

Up to twice the legitimate rate, 99 to 100% of the attack leaks (Figure 3): a shared key stays above 0.3 conversion until failures outnumber legitimate sends about $(0.8 - 0.3)/0.3 \approx 1.7$ to one, and the penalty alone reaches only *delay*. At five times, 95% leaks and 6.5% of legitimate users are challenged; at ten times, 70% leaks, 17% are challenged and 3.3% refused. Claim C2 (the farm leaks at least 90% with caps lifted) held in 34 of 36 cells.

Table 5: One-at-a-time sensitivity (not a joint search), farm, caps lifted, ten seeds. Grid: conversion weight 0/10/25/40; fresh-fingerprint weight 0–40 by 10; boundary scale 0.6–1.4 by 0.2; resolution window 60–600s; flood points 0/15/30. Unlisted rows leak within 2 messages and challenge within 3.2 points of the default.

Parameter	Value	Leaked	Challenged	Refused	Completed
default	—	99.5%	1.5%	1.3%	79.1%
boundary scale	0.6	63.6%	17.9%	4.6%	76.4%
fresh-fingerprint weight	30	97.0%	6.4%	2.7%	78.0%
fresh-fingerprint weight	40	0.0%	46.6%	8.6%	73.0%

The conversion weight and window change nothing (Table 5): the signal never fires on these keys. A fresh-fingerprint weight of 40 stops the attacker by challenging 47% of legitimate users and refusing 9%, because most legitimate sign-ups are new browsers too; at 30 it does almost nothing. Whether that price is worth paying depends on a service objective we did not define.

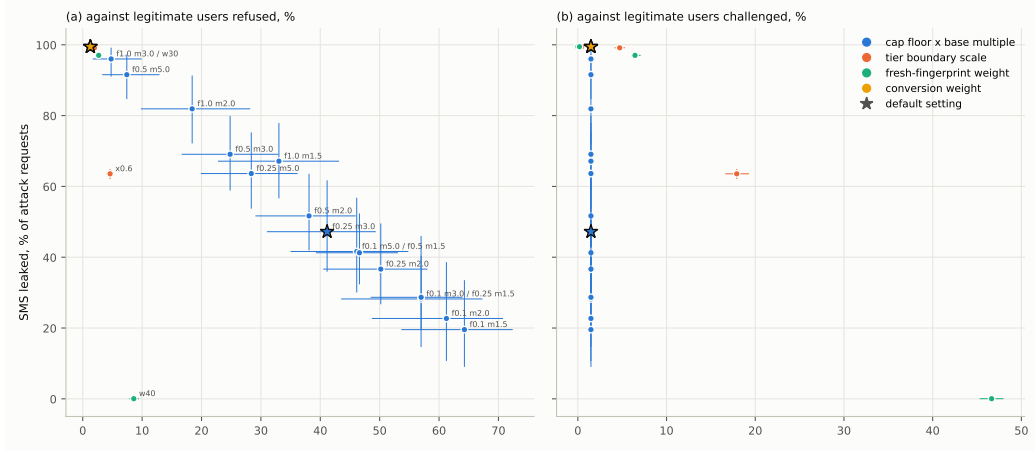


Figure 4: Farm leakage against legitimate users refused (a) and challenged (b), ten seeds, bootstrap intervals: cap floor and base multiple, caps on (f, m); risk-score settings of Table 5, caps lifted (x, w). Stars mark defaults; settings near 100% leakage are unlabelled. Sampled points, not an optimised frontier.

286 In the settings run, reputation separated an attacker only on keys its sends
 287 dominated, never a shared key [13].

288 7.4. RQ4: what rationing costs, and what it depends on

289 When separation fails, the cap is the lever (Figure 4): the default (floor
 290 0.25, base three times the legitimate rate) lets 47% of the farm’s requests
 291 through and refuses 41% of all legitimate users; the tightest setting, 20%
 292 and 64%; no rationing refuses 1.3%.

Table 6: Farm, caps on, ten seeds: (a) baseline-job cadence and tick phase, oracle baseline; (b) the deployed job learning from the pipeline’s counters, with paired differences against the clean weekly profile.

(a) Cadence					
Cadence	Phase	Attack	Leaked	Completed	First-time ref.
1 min (default)	aligned	20 min	47%	47.5%	51.5%
2 min	aligned / offset	20 min	57 / 58%	53.6 / 54.3%	41.7 / 41.0%
5 min	aligned / offset	20 min	75 / 96%	63.8 / 76.2%	25.4 / 4.9%
10 min	aligned / offset	20 min	92 / 86%	75.1 / 71.5%	7.6 / 13.8%
hourly	either	20 min	96%	76.2%	4.9%
hourly	aligned / offset	60 min	91 / 96%	73.5 / 76.4%	9.4 / 4.8%
(b) Learned baseline					
History		Leaked (msgs)		Paired diff.	Completed
weekly profile, 3 weeks		193 [161, 229]		–	40.5%
cold start (no closed hour)		533		+340 [+239, +441]	76.2%
three closed hours		235		+42 [+28, +60]	48.4%
stale, legitimate rate halved		299		+106 [+62, +151]	58.2%
stale, legitimate rate doubled		162		–30 [–44, –19]	35.7%
poisoned at that hour each week		238		+45 [+10, +77]	49.3%
two workers; restart at minute 10		193		+0 (identical runs)	40.5%

293 The gain depends on cadence and history (Table 6). The job acts on
294 the volume accumulated since its last tick: every two minutes rations less
295 strongly than the default, every five or ten depends on the tick’s phase, and
296 an hourly job leaks 91 to 96% even of a sixty-minute attack. These are tested
297 settings, not proof that only a fast controller works. The learned job leaves
298 the static cap with no closed hour and rations harder than the oracle with a
299 weekly profile. A profile poisoned at the attack’s hour every week leaks 45
300 more messages, a stale one whose legitimate rate has halved 106 more; two
301 workers and a restart changed nothing on these seeds.

Table 7: Concentrated pumpers on three 10 000-number blocks, caps lifted, ten seeds, 130-minute warm-up: messages leaked of about 560 requests in twenty minutes (the 60-minute row is longer); seeds contained within the attack window (a finite-window property); mean minutes to containment (contained seeds) and to the first verdict; codes the carrier entered. Default: $h = \ln 1000$, $c = 1$, graded verdicts. Legitimate completion is 79.0–79.2% throughout; a dash means not applicable or not reported.

Carrier, design	Leaked (msgs)	Contained (seeds)	Containment (min)	First verdict (min)	Codes entered
never verifies: v1	560 [412, 725]	0/10	–	–	0
v2 default	89 [64, 116]	10/10	3.5 [3.0, 4.1]	3.0	0
v2, 24-h denylist	88 [64, 116]	10/10	3.5 [3.0, 4.1]	3.0	0
verifies within 1 s: v2 default	17 [16, 18]	9/10	1.4 [1.0, 2.1]	0.4	17
verifies 60% after 30 s: v1	560	0/10	–	–	331
v2 default	405 [319, 487]	2/10	9.0 [5.0, 13.0]	15.2	238
v2 default, 60 min	898 [656, 1136]	3/10	–	–	–
buys challenges: v2 default	104 [82, 127]	10/10	4.3 [3.7, 5.0]	3.0	0
v2, 24-h denylist	88 [64, 116]	10/10	3.5 [3.0, 4.1]	3.0	0
farm (control): v2 default	567 [410, 745]	0/10	–	–	0

303 A pumper whose carrier never verifies is contained in all ten windows, at
304 minute 3.5 on average, after 89 messages (Table 7); one that verifies within
305 a second is caught by the speed test at 17. A challenge buyer leaks 104;
306 the denylist saves sixteen of them by locking three blocks out for a day.
307 The hard case is the carrier verifying 60% with human-like delay: the first
308 verdict comes at minute 15 on average, two windows of ten end contained,
309 and 405 messages leak while 238 codes are entered; over sixty minutes 898
310 leak and seven runs are never contained. Claim C3 (a never-verifying pumper
311 is contained with at most 30% leaked) held in 36 of 36 cells.

312 Across 18 spread configurations, leakage follows the blocks touched (Fig-
313 ure 5): with 30 blocks six or seven runs in ten are still contained, with about
314 240 none. In the ten unsaturated configurations the mean absolute per-run
315 error of Equation (2) is 1.2 to 10.7 messages (1 to 14%); in the eight saturated
316 ones it overstates by 4 to 22 on average and by up to 94 in one run.

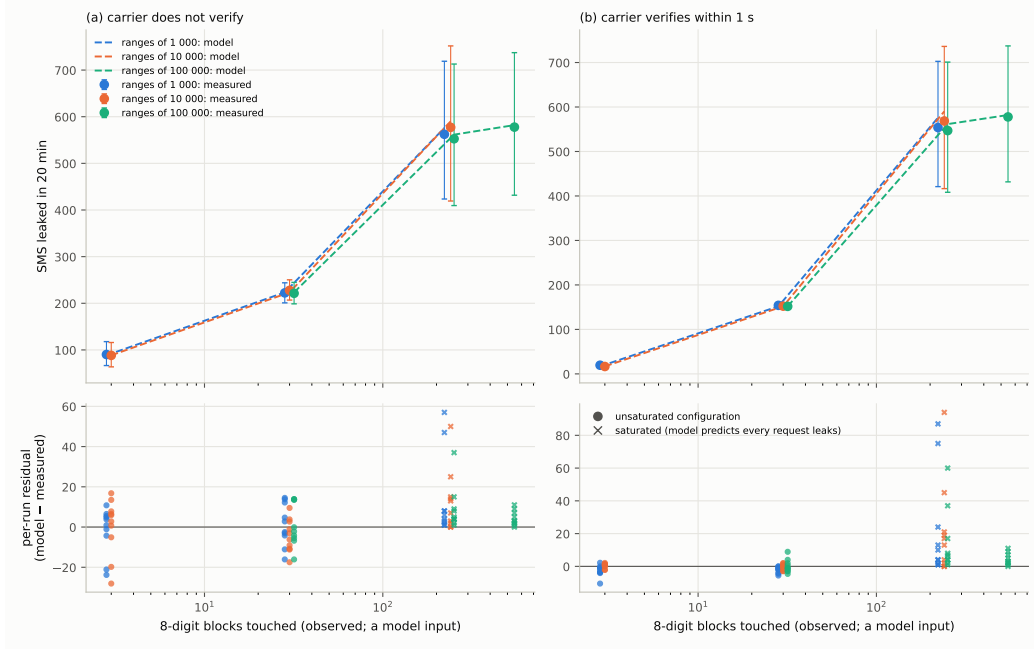


Figure 5: Pumper spread, ten seeds: leakage against blocks touched (a model input) for ranges inside, aligned with or spanning the 8-digit key; dashed lines are Equation (2); lower panels show per-run residuals, crosses where the model is saturated.

317 7.6. Destination policies on a common pipeline

Table 8: Matched comparison at 200 blocks (144 legitimate sends per block per day), ten evaluation seeds, settings selected on three tuning seeds. Leakage in twenty minutes by never-verifying (NV), instant (IV), human-like (HL) and challenge-buying (CB) carriers; over 24 hours at 65% conversion and 70% reachability, completion, attributable loss, challenge rate and verdict events per day. Matched rows: lowest threshold per credit whose tuning-seed events did not exceed the default's (none without credit).

Setting (selected as)	NV	IV	HL	CB	Compl.	Attrib. loss	Chall.	Events
none	323	556	560	401	64.13%	–	1.53%	0
sequential $T1000$, $c1$ (default)	89	17	405	104	64.13%	0.01%	1.62%	5.8
sequential $T300$, $c0$ (best at target)	87	14	118	99	63.79%	0.34%	6.24%	314.4
sequential $T10000$, $c0.5$ (matched alarms)	98	24	405	111	64.13%	0.00%	1.59%	3.8
sequential $T1000$, $c2$ (matched alarms)	89	17	538	104	64.13%	0.00%	1.58%	3.1
sequential $T1000$, unbounded (matched)	89	17	560	104	64.13%	0.00%	1.58%	3.1
counter, graded, 4 per 10 min (best)	24	24	24	48	64.07%	0.06%	2.38%	0
counter, graded, 160 per day (best)	323	411	410	401	64.11%	0.02%	1.87%	0
counter, refusing, 320 per day (best)	323	551	553	401	64.13%	0.00%	1.53%	0

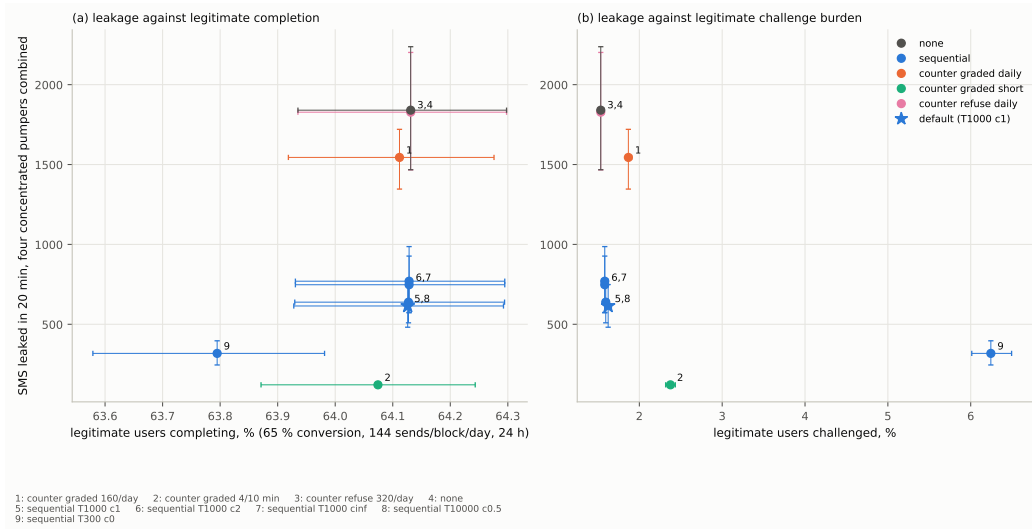


Figure 6: Table 8 as points: leakage summed over the four pumpers against completion (a) and challenge rate (b); bootstrap intervals over seeds are unpaired, so wider than the paired differences. Sampled operating points, keyed below the plot; the default is starred.

Table 8 and Figure 6 change only the destination policy. Against a carrier that never verifies, every sequential setting leaks 87 to 98: the statistic only climbs. Against the human-like carrier, the best sequential setting at the service target, *T*300 without credit, leaks 118 but raises 314 false verdict events a day; at the default’s false-alarm burden every credit leaks 405 or more. A graded counter of four sends per block per ten minutes leaks 24 against each outcome-reading carrier (more than the default’s 17 against the instant verifier) and 48 against the challenge buyer, at an attributable loss of 0.06% [0.05, 0.07] of users (0.07% at 80% conversion). Selected short-window counters did the same at other densities: three per hour at 29 sends per block per day leaks 9 (18 against the challenge buyer) at 0.35% (0.43% at 80% conversion) while challenging 7.1% of users, and one per ten minutes on uniform traffic leaks 6 (12) at 0.15% (0.18%). The selected daily counters leaked more: 323 to 553 at 200 blocks, 119 to 239 at 1000 and 29 to 59 on uniform traffic.

The reason is mechanical. A concentrated pumper sends about ninety messages per block per ten minutes and a busy legitimate block about one, so a volume limit separates them whatever the carrier does with the codes, while sequential tests read outcomes the carrier controls. The counter’s cost

depends on the fallback channel: a graded daily counter of 20 completes 27% of registrations with no WhatsApp reachability, 53% at 70% and 64% at full reachability, against 64% for the sequential default at each. The short-window counter was not run at other reachabilities, against spread pumpers or beyond twenty minutes; its allowance grows with blocks touched and windows elapsed, 72 messages an hour on three blocks and twice that for a challenge buyer.

7.7. RQ5: what destination policies cost legitimate users

A Monte Carlo of the deployed tests on one block from empty statistics, 20 000 trials per cell, gives the probability of at least one verdict over 30 legitimate sends: 0.09% [0.06, 0.14] at 80% conversion with 20% autofill, 1.9% at 65% conversion and 19.5% at 50%; conversion is the sensitive assumption. Over 24 hours of legitimate traffic (ten seeds) the default raises 0.5 verdict events a day on 200 busy blocks at 80% conversion and 5.8 at 65%, meeting 27 of about 28 800 requests; on 1 000 blocks, 1.6 and 17.9. Claim C4 (at most one verdict per 1 000 requests at conversion of 0.75 or more) held in 18 of 18 cells, and in 8 of 18 below 0.75, where it was reported, not judged. A thirty-minute outage on one prefix raises 0.6 to 0.8 verdict events, against 1.8 with send-clocked tests.

Table 9: The block poisoner, caps lifted, ten seeds; 20-minute runs except recovery (70 minutes, attack stops at minute 10). Verdict events (stage 1 / 2), blocks with a verdict, legitimate requests that met one, those never completed (descriptive), and completions lost because of enforcement, against the observe-only counterfactual on the same trace (attributable).

Variant, WhatsApp	Events	Blocks	Hit	Never compl.	Attributable (% users)		Compl.
graded, 70%	16.1 (12.9 / 3.2)	12.9	98	31.7	11.5	[4.5, 19.4]	2.80 76.2%
graded, 0%	16.7 (12.9 / 3.8)	12.9	98	46.0	25.8	[7.4, 49.1]	6.26 72.7%
graded, 100%	16.1 (12.9 / 3.2)	12.9	98	26.6	6.4	[3.1, 9.8]	1.56 77.4%
24-h denylist, 70%	17.9	12.9	121	121.2	97.7	[52.0, 146.8]	23.93 55.0%
recovery, graded, 70%	11.3 (9.0 / 2.3)	9.0	420	135.5	47.6	[17.4, 82.3]	3.35 75.5%

An attacker can aim verdicts at legitimate users (Table 9). Flooding the twenty blocks they concentrate on earns 16 verdict events and costs 11.5 completions, 2.8% of users; without fallback, 6.3%; with the denylist, 23.9%. A poisoner that stops after ten minutes leaves verdicts that meet 406 more requests over the next hour, an attributable loss of 47.6. Grading limits the harm; it caps it neither at a challenge nor at the attack’s duration.

362 7.8. Adaptive attackers, alternatives, economics and overhead

363 These are scripted adaptations, not an optimised adversary; their leakages
364 are observations, not worst-case bounds. Pumpers on a known elevated-cost
365 range leak 7 and 20. A datacenter attacker buying every challenge solution
366 leaks 55; low-and-slow attacks leak at their own rate. The trust builder’s 500
367 pairs leak 263 while verifying for ten minutes, then 253 of 289 flood requests.
368 A threshold-aware carrier leaks 560 with no verdict, and a receipt faker 560
369 (228 with caps on). Receipt-robust tests, counting failed receipts outside an
370 outage, stop the receipt faker at 16 but raise 30 false verdict events a day
371 instead of 1 on 200 blocks with a poor route; a trust budget of eight exempt
372 requests a minute trims three of four trust-builder cells by 23 to 40 messages
373 at no measured cost. Neither touches the threshold-aware carrier. A counter
374 reads no outcomes, but these carriers were not run against it.

375 In scenario accounting that credits pumpers with a share of the 0.1422
376 USD retail price and charges an event-level bill (tokens for every session at-
377 tempt and request, solved challenges, proxy traffic), the attacker breaks even
378 at a share of 0.04 under v1; under v2, at 0.27 for the never-verifying pumper,
379 0.23 for the challenge buyer and 0.06 for the human-like carrier, while the
380 instant verifier would need 1.39, more than the whole price. Preparation,
381 numbers and carrier contracts are omitted, so these are lower bounds.

382 On a real Redis (four vCPUs, four workers), a send costs 13.9 ms at the
383 median and 27.6 ms at the 99th percentile, with 49 round trips. With the
384 400 ms floor and 50 ms vendor calls, throughput is 68, 113 and 136 requests
385 per second at concurrency 32, 64 and 128, with 0, 7 and 30% of requests
386 over the floor. Under an adversarial mixture with heavy-tailed vendors and
387 1% timeouts, 21 and 63% exceed the floor at concurrency 32 and 128. With
388 the floor and instantaneous fake vendors, no pair of five outcome classes was
389 distinguished by a Kolmogorov–Smirnov test (smallest $p = 0.32$) and mean
390 differences were under 0.5 ms: a failure to detect a difference, not proof of
391 none; requests over the floor are distinguishable by construction.

392 8. Discussion

393 *Lessons.* Count on the key the attacker cannot rotate, and do not ask the
394 attacker’s carrier whether its traffic is real: outcome-based destination tests
395 were defeated by carriers that verify with human-like delay, fake receipts or
396 know the thresholds, while a short-window send counter held every pumper
397 tested to 6 to 48 messages in twenty minutes at a small attributable cost,

398 given a fallback channel. Reputation separated attackers only on keys they
399 dominated, and rationing, at the tested settings, depended on a fast controller
400 with history.

401 *Limitations.* Everything is simulated and the calibration is assumed; inter-
402 vals cover seeds, not those choices. The robustness study bounds the claims
403 to its ranges and held-out family, and its pairing repair followed the first
404 run’s failure. Some results follow from the generator (premium numbers in
405 a perfect list, a datacenter attacker that declines challenges, a farm with
406 human scores). Matched attributable loss is the false-alarm cost, measured
407 without an attack. Reachability is drawn per request, not per number; re-
408 turning users have trusted numbers but no fingerprint history. The counter
409 was not tested against spread, long or adaptive pumpers. Two state-machine
410 interleavings remain open, Step 11 is not one transaction, vendor adapters
411 are untested live, and the timing tests exclude heavy tails and 403 responses.
412 Replaying real traffic is the experiment this paper most needs.

413 *Ethics and privacy.* Verdicts challenge people for what strangers sharing their
414 network or block did, and fingerprints are kept for 90 days; deployment under
415 the GDPR or Saudi Arabia’s PDPL needs a lawful basis and a route for
416 refused users. No human data was used.

417 9. Conclusion

418 In this simulation, under the tested settings, the design contains attacks
419 that carry a signature at little cost to simulated users, and a never-verifying
420 pumper at a cost a closed-form estimate reproduces. It rations, rather than
421 separates, a residential attacker that looks like a person, refusing half of
422 first-time users. Its outcome-based destination tests are defeated by carriers
423 that verify with human-like delay, fake receipts or know the thresholds; a
424 short-window send counter leaked less in total at every density, though more
425 against the instant verifier on busy blocks.

426 Artifact availability and supplementary material

427 Code, simulation, results and scripts:
428 <https://github.com/nahmedpsu/OTP-DDOS>, release 2.7.0 (a DOI will be
429 added on acceptance). `make results` regenerates the evaluation; `results/`
430 `study_specs.json` gives every run’s configuration, `config/`

431 `evaluation_protocol.json` the protocol, and `results/`
432 `headline_numbers.md` each headline number's source. The full tables
433 (`results/evaluation.md`, `results/performance.md`) and the first
434 robustness run (`results/robustness_first_run.md`) are the
435 supplementary material.

436 **CRedit authorship contribution statement**

437 **Naveed Ahmed:** Conceptualization, Methodology, Software, Validation,
438 Investigation, Writing – original draft, Writing – review & editing.

439 **Declaration of competing interest**

440 The author declares no known competing financial interests or personal
441 relationships that could have appeared to influence this work.

442 **Declaration of generative AI and AI-assisted technologies in the** 443 **writing process**

444 The author used Claude (Anthropic) to assist with code, the evaluation,
445 and drafting and editing, checked the numbers against the recorded results
446 and the claims against the code, and takes full responsibility for the content.

447 **Data availability**

448 No real traffic data was used; all synthetic data, seeds and results are in
449 the repository.

450 **References**

- 451 [1] MITRE Corporation, Resource hijacking: SMS pumping, technique
452 T1496.003, MITRE ATT&CK, <https://attack.mitre.org/techniques/T1496/003/>, accessed 1 October 2026.
- 454 [2] Commsrisk, Elon Musk says Twitter lost \$60mn a year because 390
455 telcos used bot accounts to pump A2P SMS, <https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/>, trade press report of a
456 public statement; the figure is the company's own claim (2023).
457
458

- 459 [3] J. H. Huh, H. Shin, S. Ahn, H. Yi, J. Cho, T. Kim, M. Lim, N. Choi,
460 Preventing artificially inflated SMS attacks through large-scale traffic in-
461 spection, in: 34th USENIX Security Symposium, USENIX Association,
462 Seattle, WA, 2025.
- 463 [4] M. Sahin, A. Francillon, P. Gupta, M. Ahamad, SoK: Fraud in telephony
464 networks, in: 2017 IEEE European Symposium on Security and Privacy
465 (EuroS&P), IEEE, 2017. doi:10.1109/EuroSP.2017.40.
- 466 [5] M. Sahin, A. Francillon, Understanding and detecting international rev-
467 enue share fraud, in: Network and Distributed System Security Sympo-
468 sium (NDSS), Internet Society, 2021. doi:10.14722/ndss.2021.24051.
- 469 [6] Twilio Inc., Verify fraud guard, [https://www.twilio.com/docs/veri-
470 fy/preventing-toll-fraud/sms-fraud-guard](https://www.twilio.com/docs/verify/preventing-toll-fraud/sms-fraud-guard), product documenta-
471 tion. Accessed 1 October 2026.
- 472 [7] Twilio Inc., SMS pumping risk score (Lookup v2), [https://www.twil-
473 io.com/docs/lookup/v2-api/sms-pumping-risk](https://www.twilio.com/docs/lookup/v2-api/sms-pumping-risk), product documen-
474 tation. Accessed 1 October 2026.
- 475 [8] M. Motoyama, K. Levchenko, C. Kanich, D. McCoy, G. M. Voelker,
476 S. Savage, Re: CAPTCHAs – understanding CAPTCHA-solving ser-
477 vices in an economic context, in: 19th USENIX Security Symposium,
478 USENIX Association, 2010.
- 479 [9] A. Dionysiou, E. Athanasopoulos, SoK: Machine vs. machine – A sys-
480 tematic classification of automated machine learning-based CAPTCHA
481 solvers, Computers & Security 97 (2020) 101947. doi:10.1016/j.cose
482 .2020.101947.
- 483 [10] D. Dean, A. Stubblefield, Using client puzzles to protect TLS, in: 10th
484 USENIX Security Symposium, USENIX Association, 2001.
- 485 [11] X. Mi, X. Feng, X. Liao, B. Liu, X. Wang, F. Qian, Z. Li, S. Alrizah,
486 L. Chen, Y. Qian, Resident evil: Understanding residential IP proxy
487 as a dark service, in: 2019 IEEE Symposium on Security and Privacy
488 (S&P), IEEE, 2019. doi:10.1109/SP.2019.00011.

- 489 [12] P. Richter, F. Wolsing, A. Chandrasekaran, R. Padmanabhan, M. All-
 490 man, R. Bush, A. Feldmann, A multi-perspective analysis of carrier-
 491 grade NAT deployment, in: Proceedings of the 2016 ACM Internet
 492 Measurement Conference (IMC), ACM, 2016. doi:10.1145/298744
 493 3.2987474.
- 494 [13] J. R. Douceur, The Sybil attack, in: Peer-to-Peer Systems (IPTPS
 495 2002), Vol. 2429 of LNCS, Springer, 2002, pp. 251–260. doi:10.100
 496 7/3-540-45748-8_24.
- 497 [14] A. Wald, Sequential tests of statistical hypotheses, The Annals of Math-
 498 ematical Statistics 16 (2) (1945) 117–186. doi:10.1214/aoms/1177731
 499 118.
- 500 [15] E. S. Page, Continuous inspection schemes, Biometrika 41 (1/2) (1954)
 501 100–115. doi:10.2307/2333009.
- 502 [16] V. V. Veeravalli, T. Banerjee, Quickest change detection,
 503 arXiv:1210.5552 (book chapter) (2012). doi:10.48550/arXiv.1
 504 210.5552.
- 505 [17] NIST/SEMATECH, CUSUM control charts, section 6.3.2.3, e-handbook
 506 of statistical methods, [https://www.itl.nist.gov/div898/handbook](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm)
 507 [/pmc/section3/pmc323.htm](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm), accessed 2 October 2026.
- 508 [18] S. R. Howard, A. Ramdas, J. McAuliffe, J. Sekhon, Time-uniform, non-
 509 parametric, nonasymptotic confidence sequences, The Annals of Statis-
 510 tics 49 (2) (2021) 1055–1080. doi:10.1214/20-AOS1991.
- 511 [19] S. Wiefeling, L. Lo Iacono, M. Dürmuth, Is this really you? An empirical
 512 study on risk-based authentication applied in the wild, in: ICT Systems
 513 Security and Privacy Protection (IFIP SEC 2019), Vol. 562 of IFIP Ad-
 514 vances in Information and Communication Technology, Springer, 2019,
 515 pp. 134–148. doi:10.1007/978-3-030-22312-0_10.
- 516 [20] C. Mulliner, R. Borgaonkar, P. Stewin, J.-P. Seifert, SMS-based one-
 517 time passwords: Attacks and defense, in: Detection of Intrusions and
 518 Malware, and Vulnerability Assessment (DIMVA 2013), Vol. 7967 of
 519 LNCS, Springer, 2013, pp. 150–159. doi:10.1007/978-3-642-39235
 520 -1_9.

- 521 [21] H. Siadati, T. Nguyen, P. Gupta, M. Jakobsson, N. Memon, Mind your
522 SMSes: Mitigating social engineering in second factor authentication,
523 Computers & Security 65 (2017) 14–28. doi:10.1016/j.cose.2016.
524 09.009.
- 525 [22] N. Ahmed, OTP Guard: a layered SMS validation, risk-scoring and
526 rate-limiting pipeline against OTP flood abuse (version 2.7.0), <https://github.com/nahmedpsu/OTP-DDoS>, source code, evaluation and
527 recorded results. Archived DOI to be added (2026).
528
- 529 [23] Google LLC, SMS retriever API overview, <https://developers.google.com/identity/sms-retriever/overview>, developer documenta-
530 tion. Accessed 1 October 2026.
531
- 532 [24] Web Incubator Community Group, WebOTP API, <https://github.com/WICG/WebOTP>, specification repository. Accessed 1 October 2026.
533
- 534 [25] Twilio Inc., Verify API, <https://www.twilio.com/en-us/user-authentication-identity/verify>, product page stating a 68%+ global
535 conversion rate. Accessed 1 October 2026.
536